Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to-application connectivity without exposing internal networks.

College Name: KG COLLEGE OF ARTS AND SCIENCE

Team Id : SWTID-2026-5502

S.No	ROLL NO	NAME	EMAIL ID
1	2322KC16	GOWTHAM S	2322kc16@kgcas.com
2	2322KC17	HARINI K K	2322kc17@kgcas.com
3	2322KC18	HARSHNI K	2322kc18@kgcas.com
4	2322KC19	IMAYAVAN R K	2322kc19@kgcas.com
5	2322KC20	ISSABELLA A	2322kc20@kgcas.com

Project details

Title: Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

• AI-Enhanced User Protection (AIUP)

AI-Enhanced User Protection (AIUP) is a next-generation security framework that leverages artificial intelligence and machine learning to verify user identities and protect online platforms from cyber threats. Unlike traditional security measures that rely on static credentials like passwords or even two-factor authentication (2FA), AIUP continuously analyzes user behavior to create a dynamic, evolving "trust score" for each individual.

AIUP is essential for modern online security because it addresses the limitations of perimeter-based defenses. As cyber threats become more sophisticated—with attackers using stolen credentials, phishing, and social engineering—relying solely on "what you know" (passwords) or "what you have" (tokens) is no longer sufficient. AIUP adds a third, continuous layer: "who you are" based on how you behave. This system helps organizations prevent account takeovers, reduce fraud, and ensure that the person interacting with a platform is genuinely who they claim to be, throughout their entire session.

Abstract:

The limitations of legacy VPN architectures in addressing modern security threats, particularly lateral movement and over-privileged network access, necessitate a paradigm shift towards Zero Trust principles. This project details the comprehensive design, deployment, and management of a Zero Trust Network Access (ZTNA) solution leveraging Zscaler Private Access (ZPA) within a large-scale institutional network. The project aims to replace broad network-level access with application-specific, identity-driven connectivity. By deploying Zscaler App Connectors within the data center and integrating the platform with existing Identity Providers (Azure AD) and endpoint security tools, the architecture ensures that all user-to-application connections are established through a cloud-native broker. This approach renders internal applications "invisible" to the internet, eliminating the attack surface. Furthermore, the project explores the integration of Zscaler with security ecosystems, including SIEM platforms (like QRadar) for centralized logging and MISP for consuming threat intelligence to enable adaptive access policies. The result is a robust, scalable security framework that enforces least-privilege access, provides comprehensive audit trails, and significantly enhances the institution's resilience

Use Case Scenarios:

Scenario 1: Secure Remote Access for Faculty to ERP System

A faculty member working from home needs to access the university's ERP system to upload student grades. Using Zscaler Private Access (ZPA), they connect securely without being placed on the internal network. The system verifies their identity via Azure AD MFA and checks their device posture before granting access.

Output:

- User identity verified (Faculty_Group)
- Device posture compliant (AV active, OS up-to-date)
- Secure micro-tunnel established to ERP Application only
- Network remains completely invisible to the user

Scenario 2: External Researcher Accessing a Specific Database

An external research collaborator from another institution requires temporary access to a single research database hosted on VIT's servers. The administrator creates a time-limited, application-specific policy in Zscaler. The researcher accesses only the authorized database without any visibility into the rest of the VIT network.

Output:

- External user identity verified via temporary credentials
- Access policy enforced (Time-limited: 7 days, Application: Research-DB only)
- Database server remains hidden from internet scanners
- Session automatically terminates after policy expiry

Scenario 3: Student Access to Online Examination Portal

During final exams, thousands of students simultaneously access the internal online examination portal from various locations. Zscaler ZPA ensures that only authenticated students with compliant devices can reach the exam server. The system prevents DDoS attacks on the login page and blocks any attempts to access other internal resources.

Output:

- Mass user authentication handled via cloud scalability
- Each student connected only to the exam application

- Lateral movement to grade database or other servers blocked
- Exam server IP address remains concealed from the internet

Scenario 4: IT Administrator Performing Server Maintenance

An IT administrator needs to perform critical updates on an internal application server. Instead of connecting via VPN and gaining full network access, they use ZPA to connect directly to the specific server's management interface. The session is monitored in real-time, and any anomalous behavior (e.g., accessing unauthorized servers) is automatically terminated.

Output:

- Admin identity verified with MFA
- Direct micro-tunnel to Server-Management-Interface only
- All admin keystrokes and commands logged for audit
- Attempt to access another server automatically blocked

Scenario 5: Mergers and Acquisitions – Temporary Contractor Access

A contractor hired during a university system upgrade needs temporary access to a specific file server to migrate data. Using Zscaler ZPA, the contractor is granted application-specific access without being added to the university's Active Directory or given VPN credentials. The access is revoked automatically after the project timeline.

Output:

- Contractor identity verified via separate IdP integration
- Access granted to File-Server-Migration share only
- All file transfer activities logged in Zscaler and SIEM
- Access automatically revoked after 30-day project end date

Stage-1

Title Of the Project: -

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview: -

The project aims to develop an AI-driven identity verification system that enhances online security by analysing and verifying user identities based on their online behaviour patterns. This system uses advanced machine learning techniques to create a robust user profile, distinguishing between legitimate users and suspicious activities. It addresses the pressing issue of unauthorised access, fraudulent transactions, and cyber threats across various online platforms and services.

The primary objective is to enhance online security significantly by scrutinising and validating user identities through their online behaviour. The system employs advanced machine learning techniques such as deep learning, neural networks, and natural language processing to establish comprehensive behavioural profiles for each user, which adapt and evolve with the user's behaviour over time. Real-time anomaly detection is a key feature of the system, identifying deviations from established user behaviour profiles and responding promptly to mitigate potential security threats.

Multi-factor verification is also implemented to bolster security, triggering additional verification steps when anomalies are detected. User and administrator alerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data.

The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations.

Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours. Geographic distribution can enhance redundancy and performance by deploying components in multiple geographic regions.

Multi-factor verification is also implemented to bolster security, triggering additional verification steps when anomalies are detected. User and administrator alerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data.

The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations.

Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours. Geographic distribution can enhance redundancy and performance by deploying components in multiple geographic

List of Team Members:

Roll.no	Name	collage	Email
2322kc16	**Gowtham S**	**KG College of Arts and Science**	**2322kc16@kgcas.com**
2322kc17	**Harini K K**	**KG College of Arts and Science**	**2322kc17@kgcas.com**
2322kc18	**Harshni K**	**KG College of Arts and Science**	**2322kc18@kgcas.com**
2322kc19	**Imayavan R K**	**KG College of Arts and Science**	**2322kc19@kgcas.com**
2322kc20	**Issabella A**	**KG College of Arts and Science**	**2322kc20@kgcas.com**

STAGE-1

Top 10 OWASP:

No.	Vulnerability Category	Vulnerability Name	CWE Number
1	Access Control	Broken Access Control	CWE-284
2	Authentication	Identification and Authentication Failures	CWE-287
3	Cryptography	Cryptographic Failures (Sensitive Data Exposure)	CWE-327
4	Injection	SQL Injection	CWE-89
5	Injection	Cross-Site Scripting (XSS)	CWE-79
6	Request Forgery	Cross-Site Request Forgery (CSRF)	CWE-352
7	Configuration	Security Misconfiguration	CWE-16
8	Software Components	Vulnerable and Outdated Components	CWE-1104
9	Integrity	Software and Data Integrity Failures	CWE-494
10	Monitoring	Security Logging and Monitoring Failures	CWE-778
11	Server Vulnerability	Server-Side Request Forgery (SSRF)	CWE-918
12	Information Exposure	Sensitive Information Exposure	CWE-200
13	Transport Security	Insufficient Transport Layer Protection	CWE-319
14	Session Management	Improper Session Management	CWE-613
15	Design Flaws	Insecure Design	CWE-657

Reports:

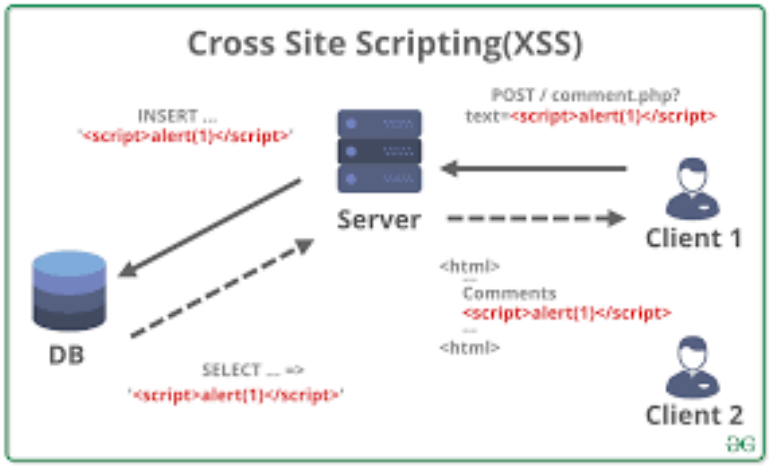
Vulnerability 1
Vulnerability name: Cross Site Scripting (Stored)
CWE: CWE-79
OWASP category: A03:2021 - Injection
Description: It occurs when a malicious script is injected directly into a vulnerable web application. Stored XSS happens when the malicious script is permanently stored on the target server such as in a database, message forum, or comment field and later executed in users' browsers.
Business Impact: The application stores dangerous data which may execute in user browsers. Attackers may steal session cookies, hijack user sessions, or perform actions on behalf of users.
Vulnerability path: http://testfire.net/
Vulnerability parameter: http://testfire.net/search.jsp?query='><script>alert('hacked')</script>
Steps to Reproduce:

- Access the URL
- Enter malicious script in search box
- Use payload '><script>alert('hacked')</script>
- Alert popup appears

Recommendation:

- Sanitize all user inputs
- Use output encoding
- Implement Content Security Policy

Screenshot:



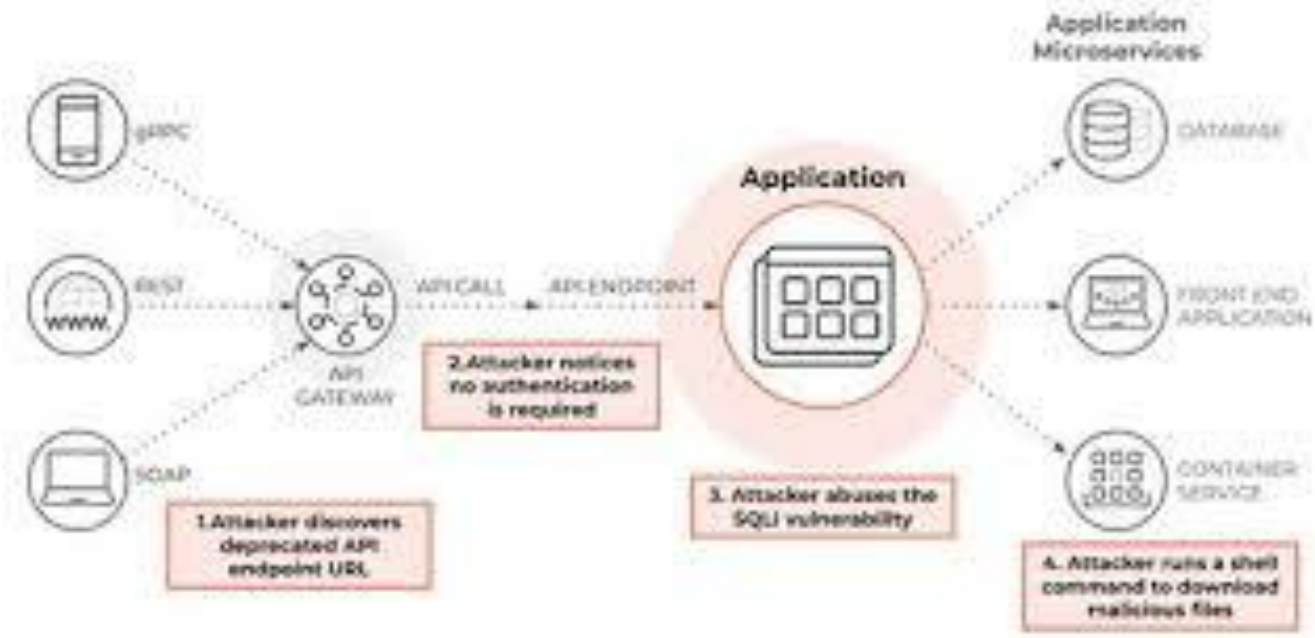
Vulnerability 2
Vulnerability name: SQL Injection
CWE: CWE-89
OWASP category: A03:2021 - Injection
Description: SQL Injection occurs when user input is included in SQL queries without proper validation or escaping.
Business Impact: Attackers can access, modify or delete database data and potentially gain administrator privileges.
Vulnerability path: http://testfire.net/login.jsp
Vulnerability parameter: username=admin' OR '1'='1
Steps to Reproduce:

- Open login page

- Enter SQL payload in username field
- Submit login request
- Authentication bypass occurs

Recommendation:
- Use prepared statements
- Validate user inputs
- Apply least privilege to DB accounts

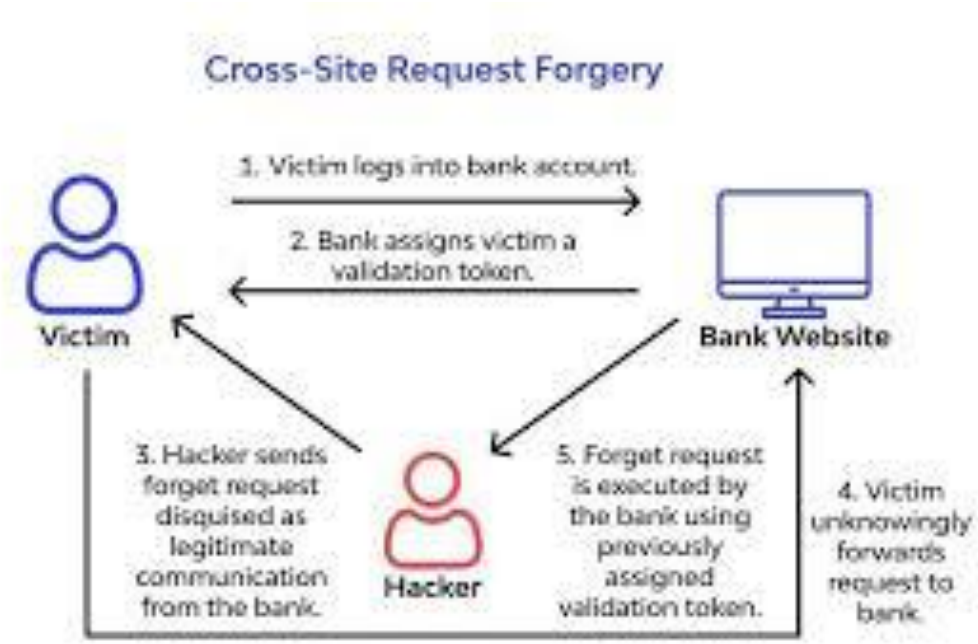
Screenshot:



Vulnerability 3
Vulnerability name: Cross Site Request Forgery
CWE: CWE-352
OWASP category: A01:2021 - Broken Access Control
Description: CSRF forces authenticated users to submit unwanted requests to a web application.
Business Impact: Attackers can perform actions like password changes or fund transfers without user consent.
Vulnerability path: http://testfire.net/account.jsp
Vulnerability parameter: transferFunds
Steps to Reproduce:
- User logs in
- Attacker sends malicious request link
- User clicks while authenticated
- Unauthorized action occurs

Recommendation:
- Use CSRF tokens
- Use same-site cookies
- Verify request origin headers

Screenshot:



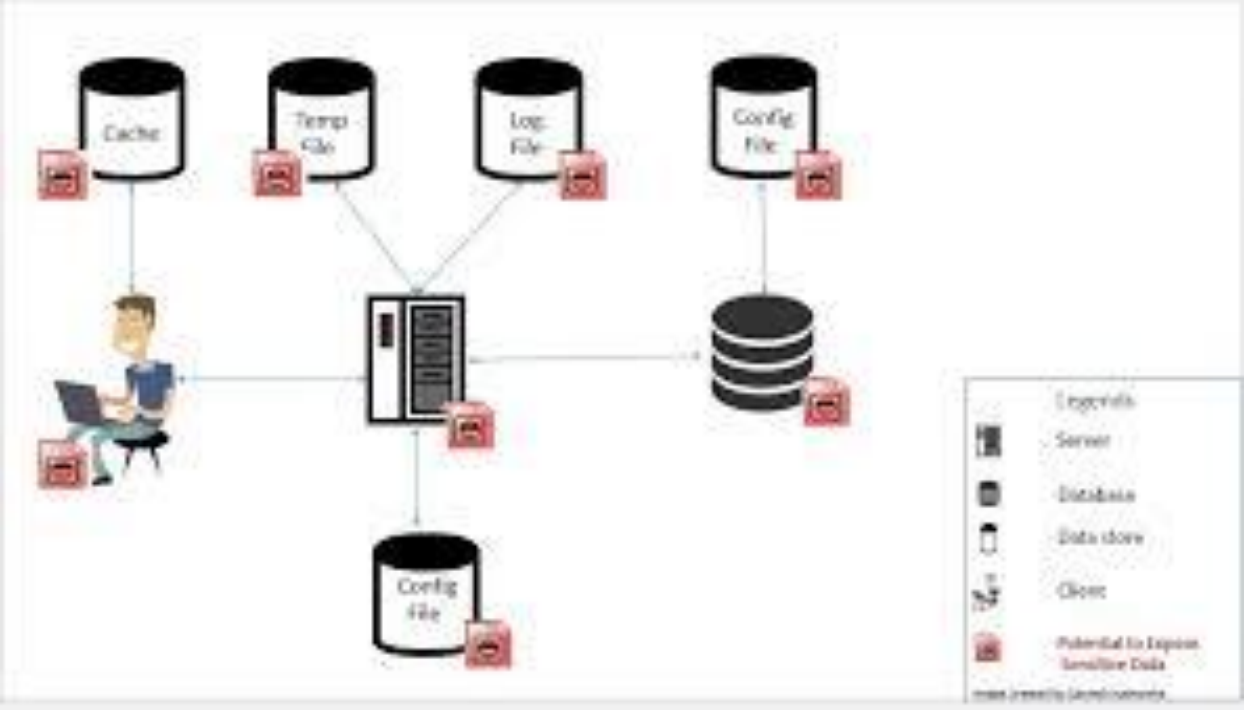
Vulnerability 4
Vulnerability name: Sensitive Data Exposure
CWE: CWE-200
OWASP category: A02:2021 - Cryptographic Failures
Description: This occurs when applications fail to properly protect sensitive information such as passwords or credit card data.
Business Impact: Attackers may intercept or steal confidential data leading to financial loss or identity theft.
Vulnerability path: http://testfire.net/profile.jsp
Vulnerability parameter: userDetails
Steps to Reproduce:

- Access profile page
- Observe sensitive data transmitted
- Capture traffic using proxy tool

Recommendation:

- Use HTTPS encryption
- Encrypt sensitive data
- Avoid storing unnecessary sensitive information

Screenshot:



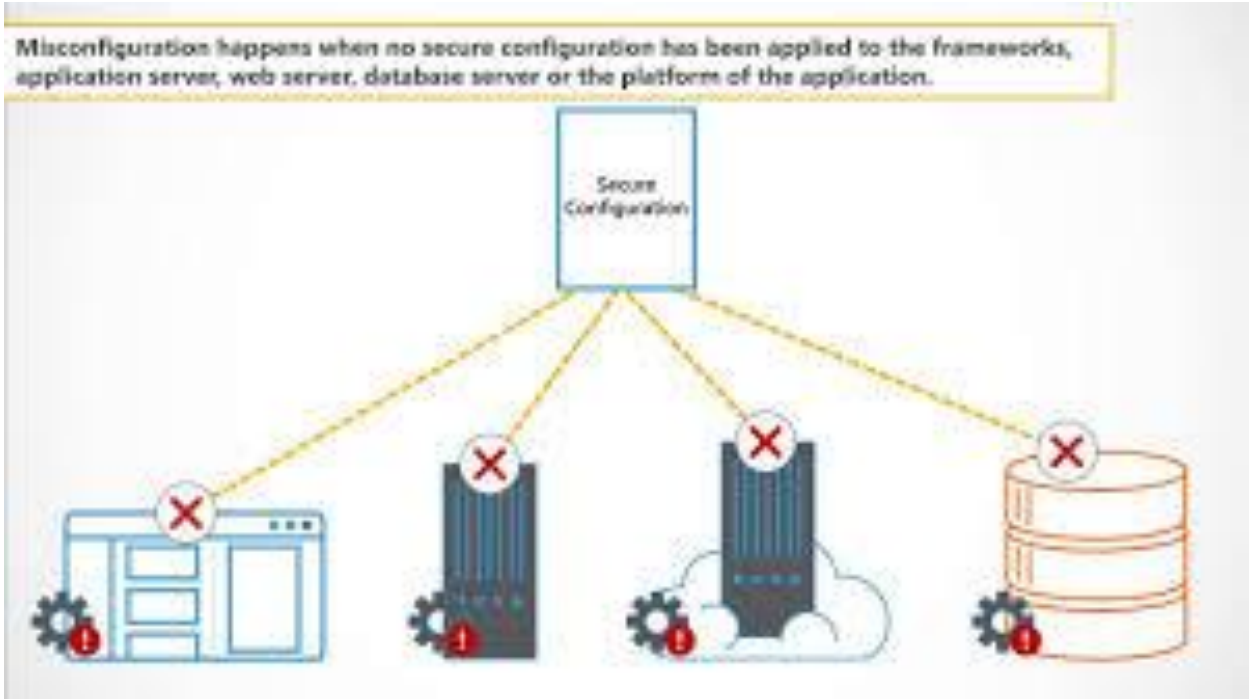
Vulnerability 5
Vulnerability name: Security Misconfiguration
CWE: CWE-16
OWASP category: A05:2021 - Security Misconfiguration
Description: Security misconfiguration occurs when security settings are not properly implemented.
Business Impact: Attackers may exploit exposed services, default credentials, or debug messages.
Vulnerability path: http://testfire.net/admin
Vulnerability parameter: default credentials
Steps to Reproduce:

- Access admin panel
- Attempt default credentials
- Gain admin access

Recommendation:

- Disable default credentials
- Harden server configurations
- Regular security audits

Screenshot:



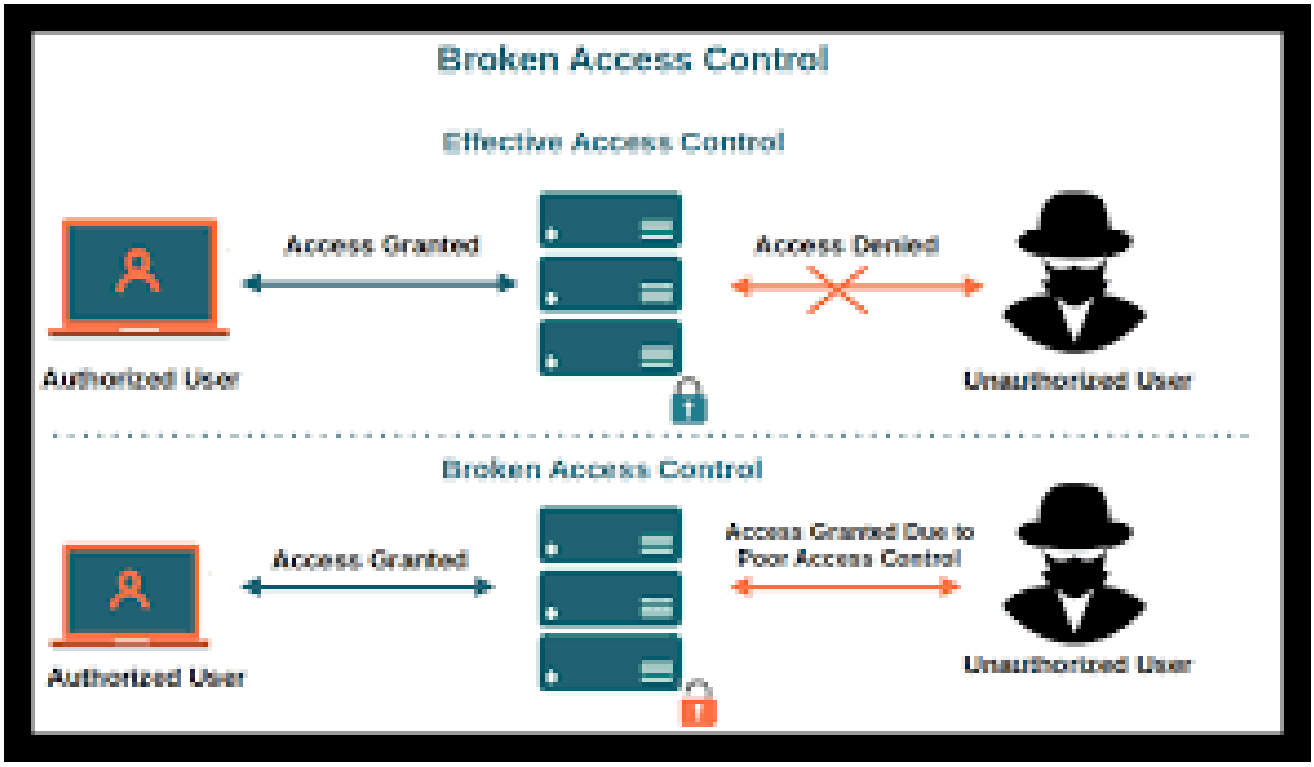
Vulnerability 6
Vulnerability name: Broken Access Control
CWE: CWE-284
OWASP category: A01:2021 - Broken Access Control
Description: Access control restrictions are not properly enforced allowing users to access unauthorized resources.
Business Impact: Attackers may access restricted files or perform administrative operations.
Vulnerability path: http://testfire.net/admin/dashboard
Vulnerability parameter: userID=2
Steps to Reproduce:

- Login as normal user
- Modify URL parameter
- Access admin dashboard

Recommendation:

- Enforce server-side access checks
- Implement role-based access control

Screenshot:



Vulnerability 7
Vulnerability name: Identification and Authentication Failure
CWE: CWE-287
OWASP category: A07:2021 - Identification and Authentication Failures
Description: Improper authentication mechanisms allow attackers to compromise passwords or bypass login systems.
Business Impact: Attackers may take control of user accounts.
Vulnerability path: http://testfire.net/login.jsp
Vulnerability parameter: password guessing
Steps to Reproduce:

- Access login page
- Attempt brute-force login
- Gain account access

Recommendation:

- Use MFA authentication
- Implement account lockout
- Use strong password policies

Screenshot:

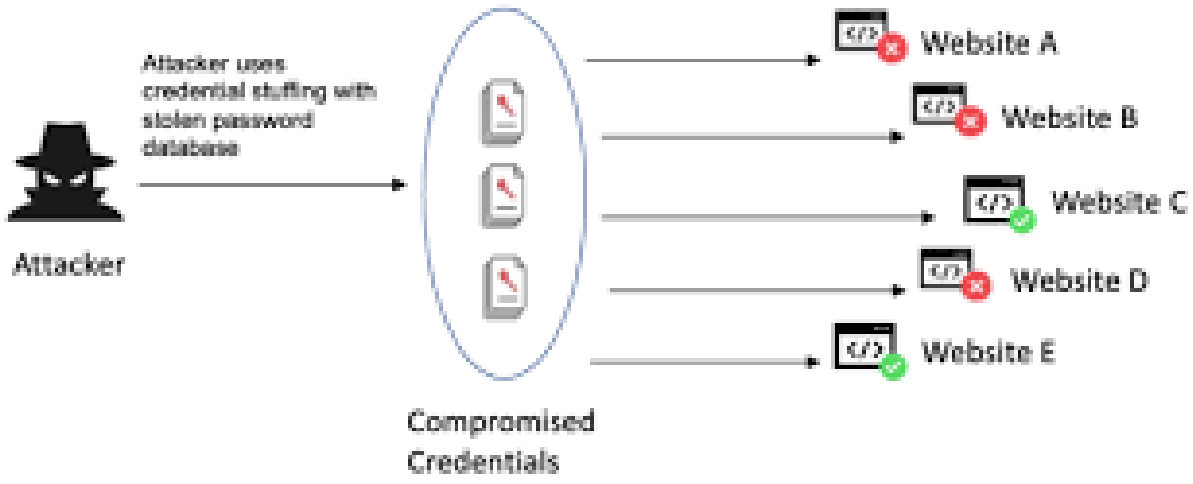


Figure: Identification and authentication failures attack scenario

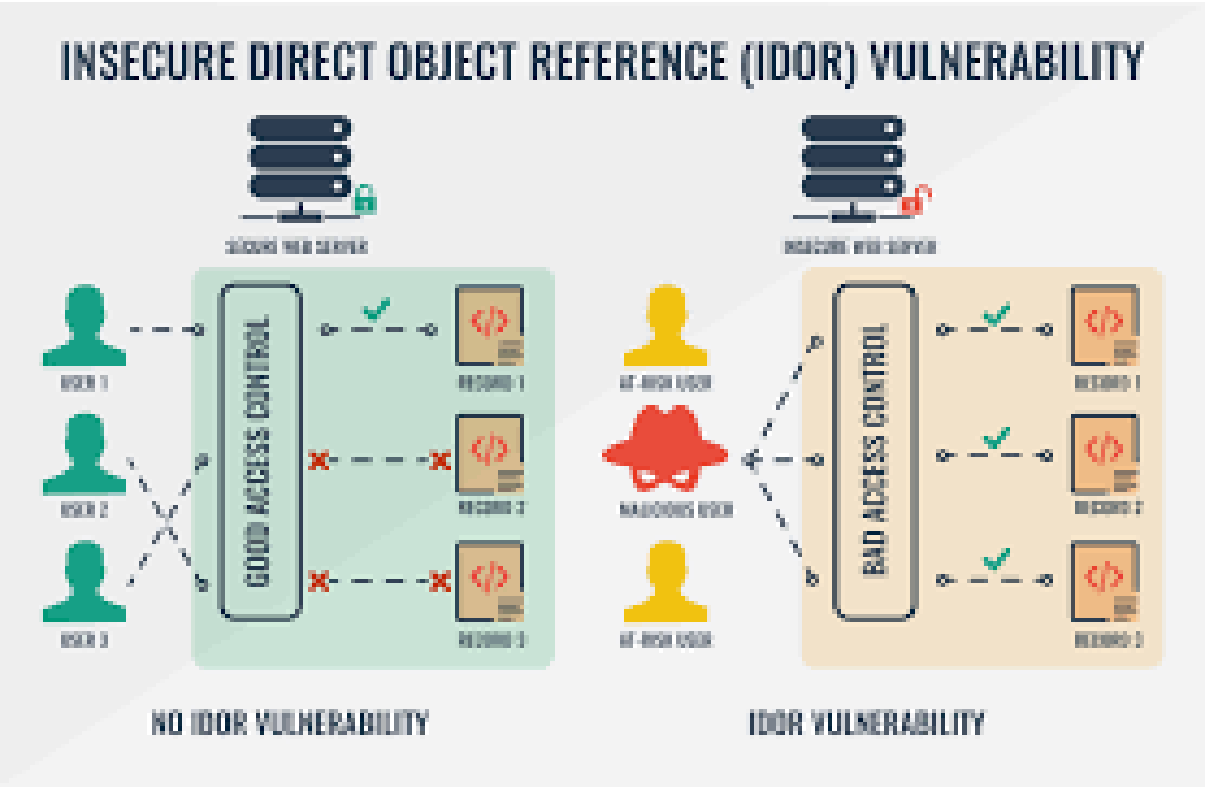
Vulnerability 8
Vulnerability name: Insecure Direct Object Reference
CWE: CWE-639
OWASP category: A01:2021 - Broken Access Control
Description: This vulnerability occurs when an application exposes internal object references without authorization checks.
Business Impact: Attackers can access other users' data by modifying object identifiers.
Vulnerability path: http://testfire.net/account?id=1001
Vulnerability parameter: id parameter
Steps to Reproduce:

- Login to application
- Change ID parameter in URL
- Access another user's data

Recommendation:

- Validate user permissions
- Use indirect object references

Screenshot:



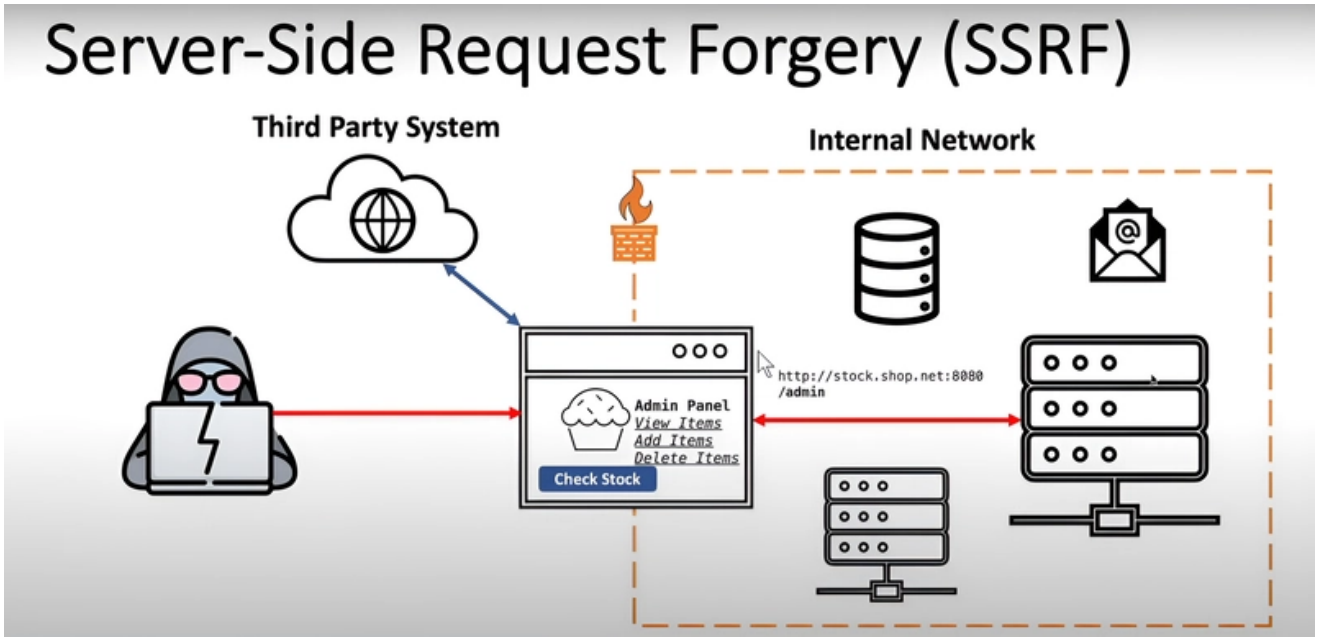
Vulnerability 9
Vulnerability name: Server-Side Request Forgery
CWE: CWE-918
OWASP category: A10:2021 - Server-Side Request Forgery
Description: SSRF allows attackers to force the server to make requests to internal systems.
Business Impact: Attackers may access internal services or sensitive metadata.
Vulnerability path: http://testfire.net/fetch?url=
Vulnerability parameter: url parameter
Steps to Reproduce:

- Enter external URL
- Modify request to internal address
- Server fetches internal resource

Recommendation:

- Validate URLs
- Block internal IP ranges
- Use allow lists

Screenshot:



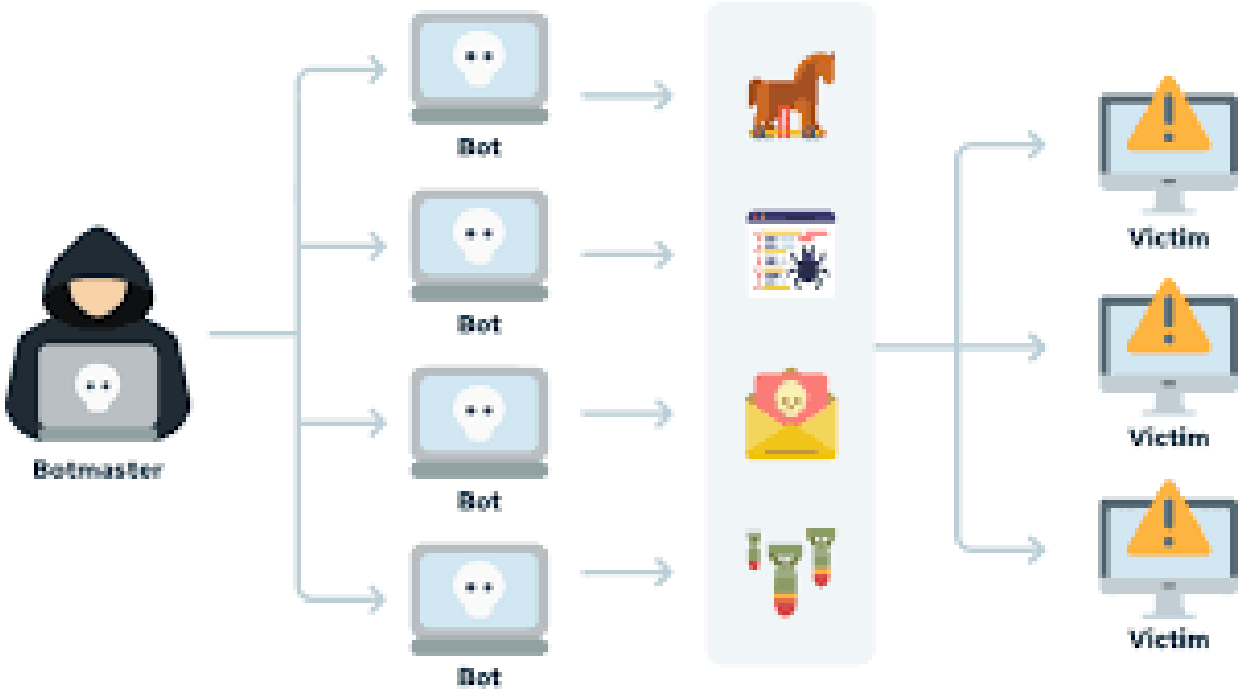
Vulnerability 10
Vulnerability name: Insufficient Logging and Monitoring
CWE: CWE-778
OWASP category: A09:2021 - Security Logging and Monitoring Failures
Description: Applications fail to log security events or monitor suspicious activities.
Business Impact: Attacks may go undetected leading to prolonged system compromise.
Vulnerability path: http://testfire.net/admin/logs
Vulnerability parameter: log monitoring
Steps to Reproduce:

- Perform multiple failed logins
- Observe absence of alerts

Recommendation:

- Enable centralized logging
- Monitor suspicious activities

Screenshot:



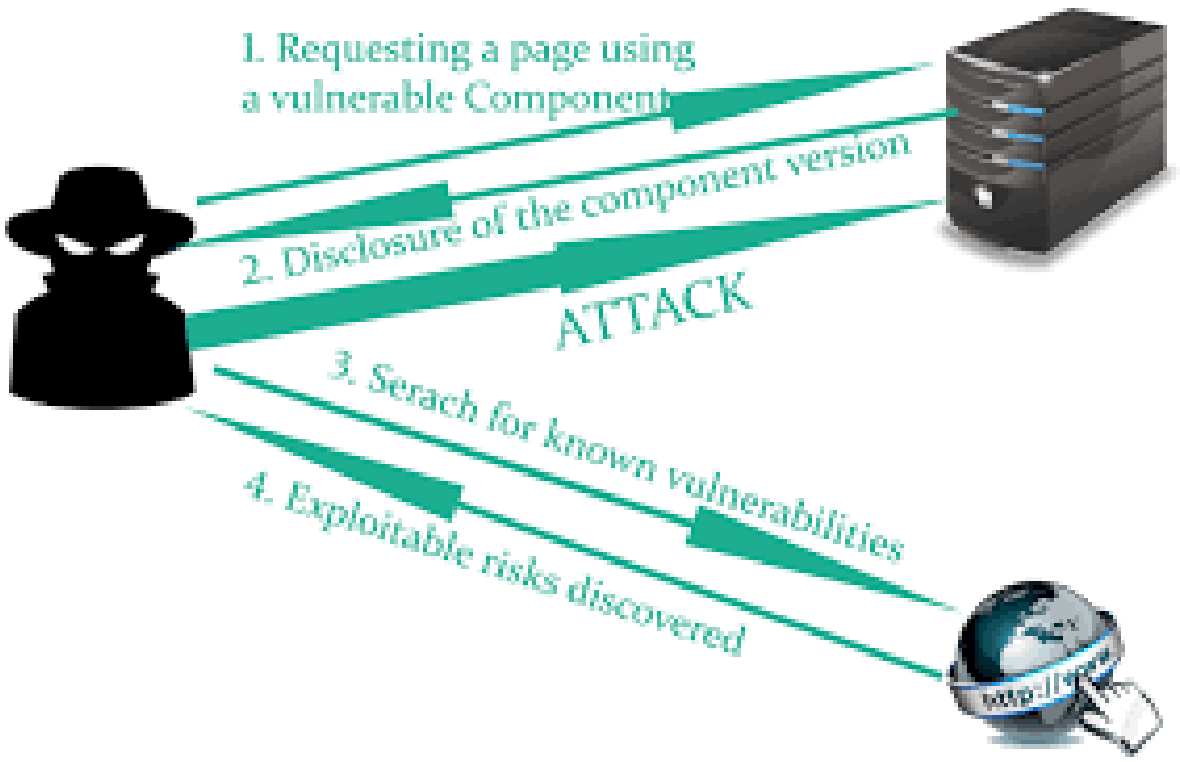
Vulnerability 11
Vulnerability name: Using Components with Known Vulnerabilities
CWE: CWE-1104
OWASP category: A06:2021 - Vulnerable and Outdated Components
Description: Applications use outdated libraries or frameworks with known security issues.
Business Impact: Attackers may exploit known vulnerabilities in components.
Vulnerability path: http://testfire.net/app
Vulnerability parameter: library version
Steps to Reproduce:

- Identify outdated library
- Exploit known vulnerability

Recommendation:

- Update libraries regularly
- Monitor vulnerability databases

Screenshot:



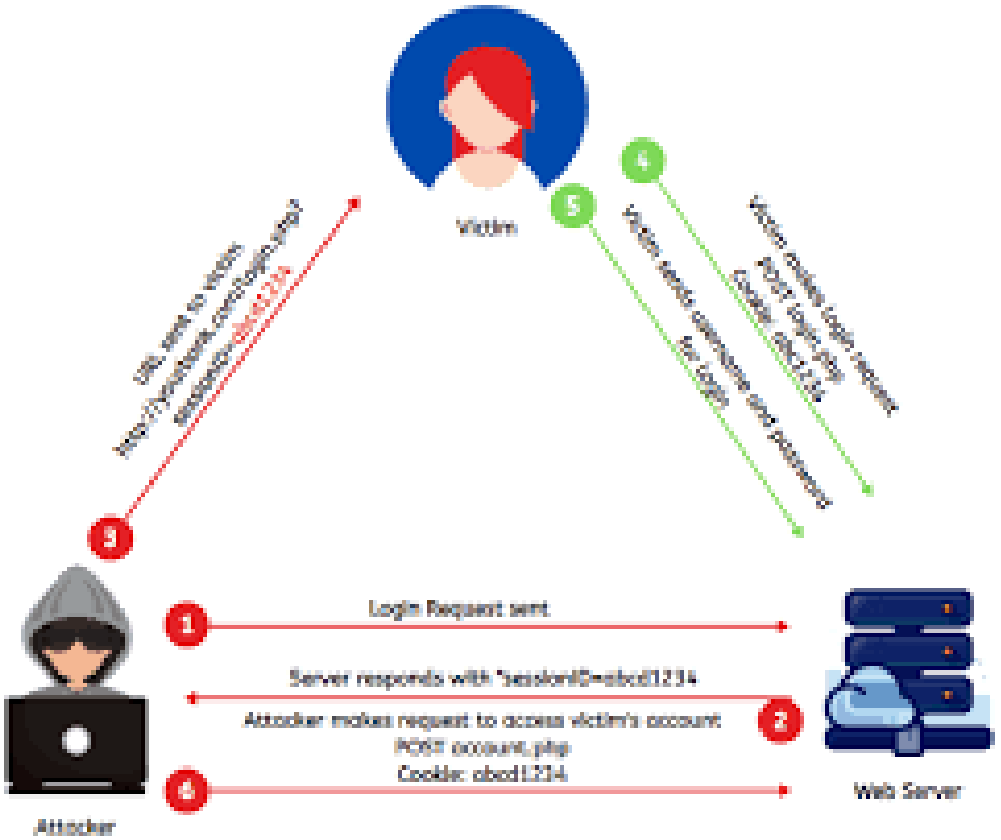
Vulnerability 12
Vulnerability name: Improper Session Management
CWE: CWE-613
OWASP category: A07:2021 - Identification and Authentication Failures
Description: Sessions are not properly managed leading to session hijacking.
Business Impact: Attackers can reuse session IDs to impersonate users.
Vulnerability path: http://testfire.net/session
Vulnerability parameter: sessionID
Steps to Reproduce:

- Login to application
- Capture session cookie
- Reuse session cookie

Recommendation:

- Use secure cookies
- Expire sessions after inactivity

Screenshot:



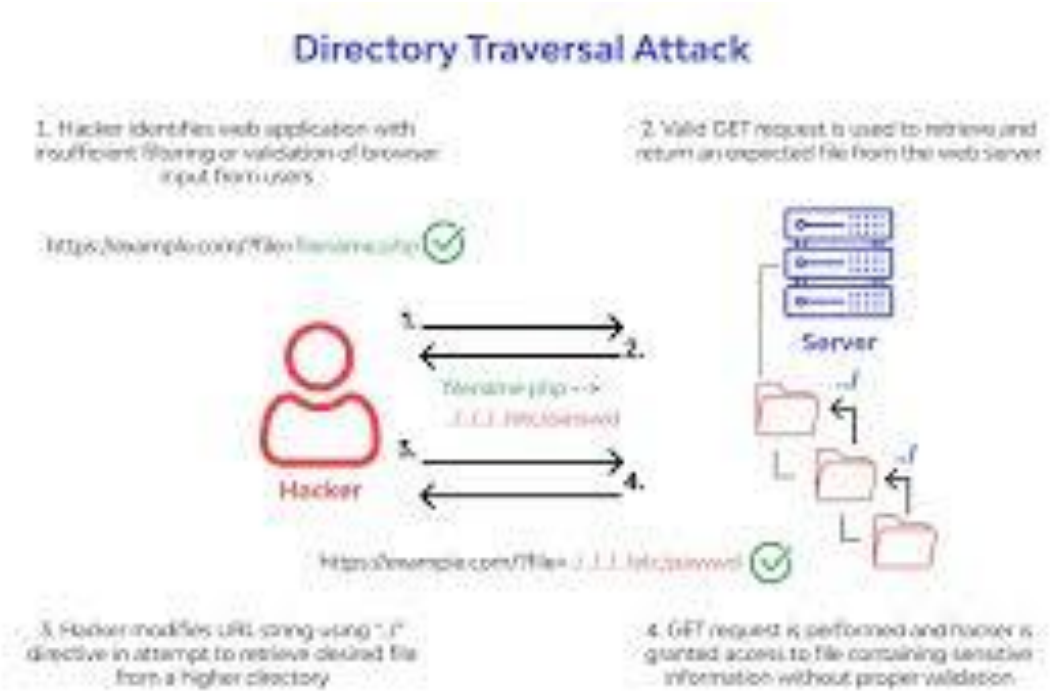
Vulnerability 13
Vulnerability name: Directory Traversal
CWE: CWE-22
OWASP category: A05:2021 - Security Misconfiguration
Description: Attackers manipulate file paths to access restricted files.
Business Impact: Sensitive files such as configuration files may be exposed.
Vulnerability path: http://testfire.net/download?file=
Vulnerability parameter: file=../../etc/passwd
Steps to Reproduce:

- Access download feature
- Modify file path
- Retrieve restricted file

Recommendation:

- Validate file paths
- Restrict directory access

Screenshot:



Vulnerability 14
Vulnerability name: Clickjacking
CWE: CWE-1021
OWASP category: A05:2021 - Security Misconfiguration
Description: Attackers trick users into clicking hidden elements within a webpage.
Business Impact: Users may unknowingly perform sensitive actions.
Vulnerability path: http://testfire.net/transfer
Vulnerability parameter: hidden iframe
Steps to Reproduce:

- Load page inside iframe
- User clicks hidden button

Recommendation:

- Use X-Frame-Options
- Implement frame busting techniques

Screenshot:

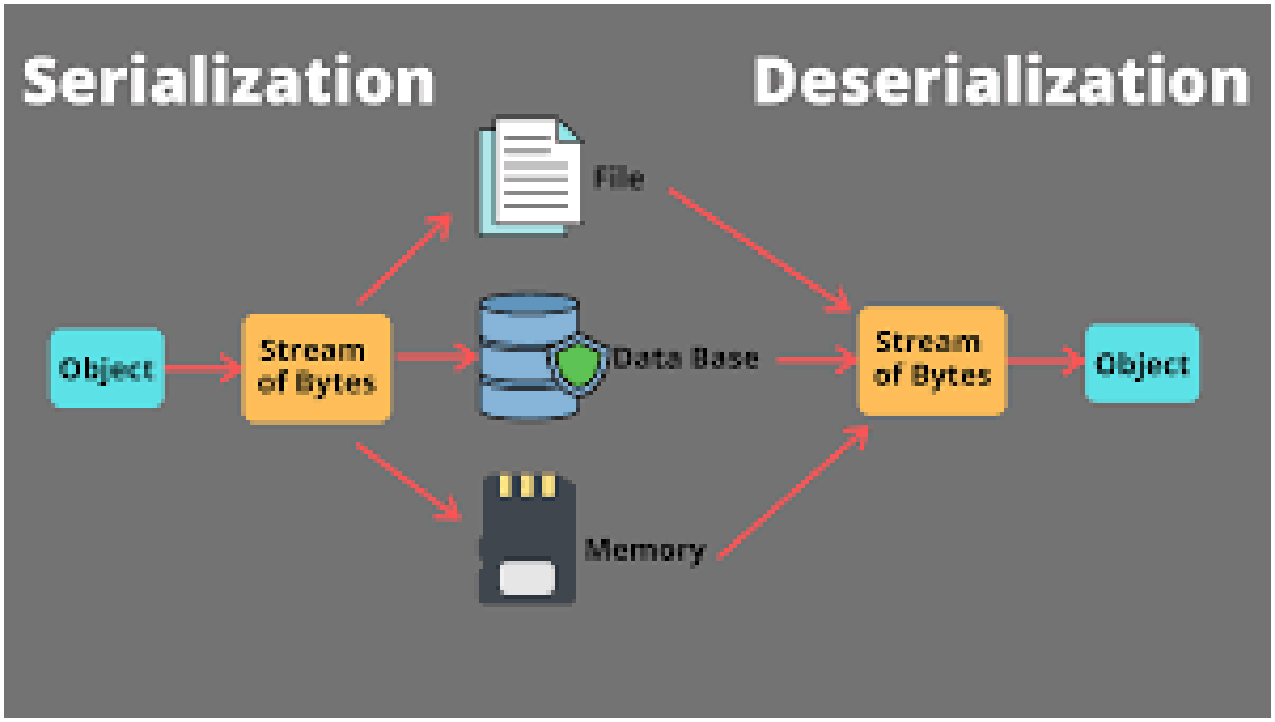
Vulnerability 15
Vulnerability name: Insecure Deserialization
CWE: CWE-502
OWASP category: A08:2021 - Software and Data Integrity Failures
Description: Untrusted serialized data is processed leading to code execution.
Business Impact: Attackers may execute arbitrary code or escalate privileges.
Vulnerability path: http://testfire.net/api/deserialize
Vulnerability parameter: serializedObject
Steps to Reproduce:

- Send crafted serialized object
- Server processes malicious object

Recommendation:

- Validate serialized data
- Avoid deserializing untrusted input

Screenshot:



STAGE-2
Nessus

Overview:

Nessus is a popular vulnerability assessment tool developed by Tenable that is used to identify security weaknesses in computer systems, networks, servers, and web applications. It helps organizations detect vulnerabilities such as outdated software, missing security patches, weak configurations, open ports, and potential malware that attackers could exploit. Nessus works by scanning the target systems and comparing the results with its continuously updated database of known vulnerabilities and security issues.

The tool uses a large collection of plugins to perform different types of security checks and vulnerability tests. These plugins allow Nessus to detect thousands of known vulnerabilities across various operating systems, databases, applications, and network devices. After completing a scan, Nessus generates detailed reports that categorize vulnerabilities based on their severity levels such as critical, high, medium, and low. The reports also include a description of each vulnerability, its potential impact, and recommended solutions or remediation steps to fix the problem.

Nessus supports multiple scanning techniques including network scanning, configuration auditing, malware detection, and web application vulnerability scanning. It also allows users to schedule scans, customize scanning policies, and monitor system security regularly. Because of its high accuracy, user-friendly interface, and regular updates, Nessus is widely used by cybersecurity professionals, penetration testers, and organizations to strengthen their security posture and protect systems from potential cyber threats

use cases of Nessus:

- Vulnerability Assessment
  Nessus is widely used to identify security vulnerabilities in networks, servers, and systems. It scans devices to detect weaknesses such as outdated software, unpatched systems, and insecure configurations that attackers could exploit.
- Network Security Monitoring
  Organizations use Nessus to monitor their network security by scanning routers, switches,

firewalls, and other network devices. This helps security teams detect open ports, weak protocols, and other network-related vulnerabilities.

- Compliance Auditing
  Nessus helps organizations meet security compliance requirements such as PCI-DSS, HIPAA, and ISO standards. It checks systems against security policies and compliance guidelines to ensure that organizations follow required security practices.
- Patch Management Support
  Nessus identifies missing patches and outdated software versions on systems. This allows administrators to update and patch their systems quickly to reduce security risks.
- Web Application Security Testing
  Security professionals use Nessus to scan web applications for vulnerabilities like SQL injection, cross-site scripting (XSS), and other common web security issues.
- Configuration Auditing
  Nessus checks system configurations to identify weak settings such as default passwords, unnecessary services, or improper security configurations that could lead to security breaches.
- Penetration Testing Support
  Ethical hackers and penetration testers use Nessus as a reconnaissance tool to gather vulnerability information before performing deeper security testing.
- Risk Management
  Nessus provides vulnerability severity ratings and detailed reports, helping organizations prioritize security issues and fix the most critical vulnerabilities first.

Features of Nessus

1. **Comprehensive Vulnerability Detection**
   Nessus can detect thousands of vulnerabilities in operating systems, network devices, databases, and web applications. It uses a large and frequently updated plugin database to identify security weaknesses.
2. **High-Speed Asset Discovery**
   The tool quickly scans networks to discover active hosts, open ports, and running services. This helps security teams understand what devices are connected to the network.
3. **Configuration Auditing**
   Nessus checks system configurations and security settings to ensure they follow recommended security standards. It can detect weak configurations such as default credentials or insecure protocols.
4. **Malware Detection**
   Nessus helps identify systems that may be infected with malware or communicating with suspicious or malicious hosts.
5. **Web Application Scanning**
   It scans web applications for common vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and other security flaws.
6. **Detailed Vulnerability Reports**
   After scanning, Nessus generates detailed reports that include vulnerability descriptions, severity levels (Critical, High, Medium, Low), and recommended solutions.
7. **Customizable Scan Policies**
   Users can create customized scanning policies depending on the network environment and security requirements.

8. **Regular Plugin Updates**
   Nessus receives regular updates from Tenable to detect newly discovered vulnerabilities.

How to Use Nessus

1. **Install Nessus**
   Download and install Nessus from the official website of Tenable. It is available for Windows, Linux, and macOS systems.
2. **Activate the Tool**
   After installation, activate Nessus using an activation code provided during registration.
3. **Access the Web Interface**
   Nessus runs through a web-based interface. Open a browser and access it using: https://localhost:8834
4. **Create a New Scan**
   Click **New Scan** and choose a scan template such as **Basic Network Scan**.
5. **Configure the Scan**
   Enter the **target IP address or domain name** of the system you want to scan and configure scan settings if required.
6. **Run the Scan**
   Start the scan. Nessus will analyze the target system and check for vulnerabilities.
7. **Review the Results**
   After the scan is completed, Nessus displays the vulnerabilities found along with their severity levels.
8. **Generate Reports**
   Export the scan results as reports (PDF, HTML, or CSV) for documentation and further security analysis.

List of vulnerability

S.No	Vulnerability Name	Severity	Plugin Id
1	HTTP (Multiple Issues)	Info	10107
2	Web Server (Multiple Issues)	Info	11239
3	Service Detection	Info	22964
4	Nessus SYN Scanner	Info	11219
5	Host Fully Qualified Domain Name (FQDN) Resolution	Info	12053
6	Nessus Scan Information	Info	19506
7	OS Fingerprints Detected	Info	209654
8	Traceroute Information	Info	10287

Reports:

1. Vulnerability Name: HTTP (Multiple Issues)

Severity: Info

Plugin: 10107

Port: 80

Description: This plugin reports general information about the HTTP service running on the target system. It identifies that the system is using an HTTP web server and may include multiple informational checks related to HTTP headers, responses, or server configuration. The result does not indicate a direct vulnerability but provides details about the web service detected during the scan.

Solution: Review the web server configuration and ensure that it is properly configured with secure settings. Keep the web server software updated and disable unnecessary services or modules.

Business Impact: Attackers may gather information about the web server configuration which could be used for reconnaissance and planning future attacks.

2. Vulnerability Name: Web Server (Multiple Issues)

Severity: Info

Plugin: 11239

Port: 80

Description: This plugin provides general information about the detected web server. It may identify the server type, version, or configuration details that help administrators understand the web services running on the host. It is mainly informational and does not indicate a confirmed vulnerability.

Solution: Regularly update the web server software and review its configuration to remove unnecessary information disclosure and unused components.

Business Impact: Information about the web server can help attackers identify possible weaknesses and target specific exploits related to the server technology.

3. Vulnerability Name: Service Detection

Severity: Info

Plugin: 22964

Port: Multiple Ports

Description: This plugin detects and identifies services running on various open ports of the target system. It helps determine which network services are available and how they respond to network requests.

Solution: Review all detected services and disable any unnecessary or unused services. Ensure that only required services are exposed to the network.

Business Impact: Unnecessary services increase the attack surface and may provide attackers with additional entry points into the system.

4. Vulnerability Name: Nessus SYN Scanner

Severity: Info

Plugin: 11219

Port: Multiple Ports

Description: This plugin indicates that the scan used the SYN scanning technique to identify open

ports on the target host. SYN scanning helps detect active services without completing full TCP connections.

Solution: Network administrators should review open ports and close any ports that are not required for business operations. Implement firewall rules to restrict unnecessary network access.

Business Impact: Open ports may expose services that attackers can attempt to exploit if not properly secured.

5. Vulnerability Name: Host Fully Qualified Domain Name (FQDN) Resolution

Severity: Info

Plugin: 12053

Port: N/A

Description: This plugin resolves and reports the Fully Qualified Domain Name (FQDN) of the scanned host. It helps identify the domain name associated with the system's IP address.

Solution: Ensure that DNS configurations are properly maintained and that unnecessary DNS information is not publicly exposed.

Business Impact: Revealing domain information may assist attackers in gathering details about the organization's network structure.

6. Vulnerability Name: Nessus Scan Information

Severity: Info

Plugin: 19506

Port: N/A

Description: This plugin provides information about the scan itself, such as the scanning engine, plugin set, and scan configuration. It is used for reporting and auditing purposes.

Solution: No direct remediation is required since this plugin only provides scan-related information.

Business Impact: There is no direct security impact, but the information is useful for documentation and compliance purposes.

7. Vulnerability Name: OS Fingerprints Detected

Severity: Info

Plugin: 209654

Port: N/A

Description: This plugin attempts to identify the operating system of the target host by analyzing network responses. The detected OS fingerprint helps determine the system type and version.

Solution: Keep the operating system updated with the latest security patches and minimize information leakage that could reveal system details.

Business Impact: If attackers identify the operating system, they may attempt exploits that specifically target that platform.

8. Vulnerability Name: Traceroute Information

Severity: Info

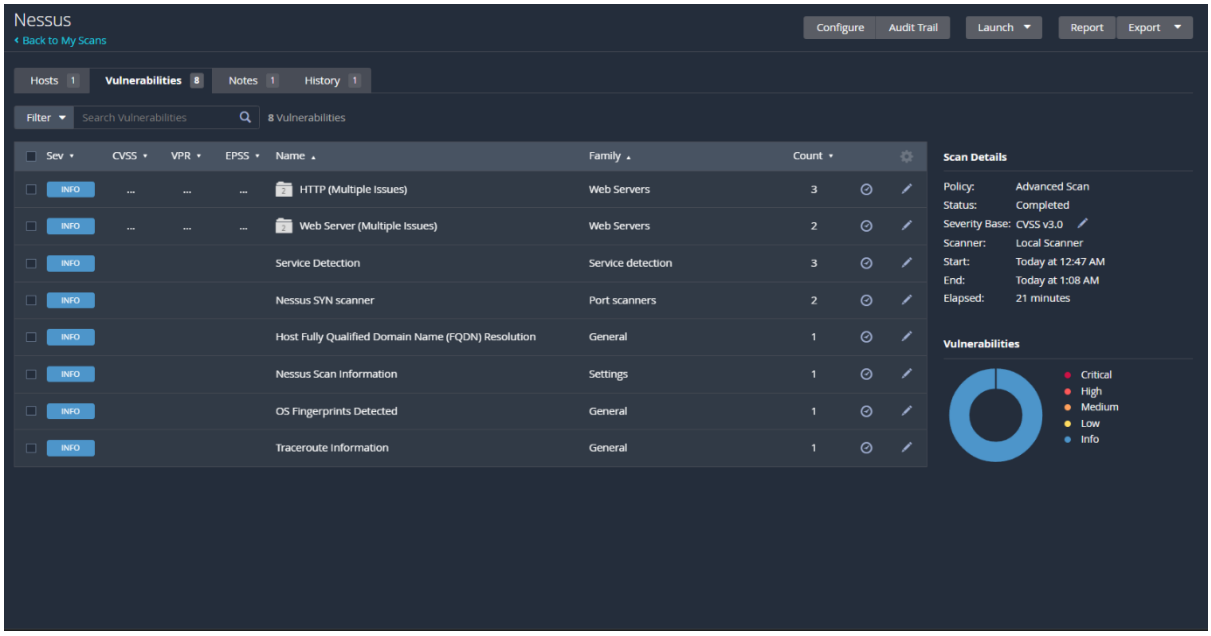
Plugin: 10287

Port: N/A

Description: This plugin performs a traceroute to identify the network path between the scanning system and the target host. It provides details about intermediate network devices and routing paths.

Solution: Restrict unnecessary ICMP responses or traceroute visibility where possible using firewall or network configurations.

Business Impact: Network path information may help attackers understand the network infrastructure and identify potential targets for further attacks.



Stage-3

REPORT

Title: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization

1. Limitations of Traditional VPN Architectures

Traditional Virtual Private Network (VPN) solutions were originally designed to provide remote users with secure access to internal corporate networks. However, these systems often grant broad network-level access once a user is authenticated, which increases the organization's attack surface. If an attacker gains access to a compromised account, they may move laterally across the network and access multiple internal resources. Additionally, legacy VPN systems require complex infrastructure, constant maintenance, and may suffer from performance bottlenecks when supporting large numbers of remote users. These limitations highlight the need for a more secure and scalable access model.

2. Zero Trust Security Model and Principles

The **Zero Trust** security model is based on the principle of **"never trust, always verify."** Instead of trusting users simply because they are inside the network, every access request must be authenticated, authorized, and continuously validated. The Zero Trust approach focuses on identity verification, device posture checks, least-privilege access, and continuous monitoring. By implementing these principles, organizations can ensure that users only access the applications and resources necessary for their role, reducing the chances of unauthorized access and internal threats.

3. Cloud-Native Secure Access with Zscaler

A cloud-native Zero Trust platform like Zscaler enables secure application access without exposing internal networks to the internet. Instead of connecting users to the network, Zscaler securely connects users directly to specific applications using encrypted micro-tunnels. This approach eliminates the need for traditional VPN gateways and reduces infrastructure complexity. Zscaler's globally distributed cloud platform also provides real-time threat protection, policy enforcement, and secure access for users working from any location or device.

4. Reducing Attack Surface and Preventing Lateral Movement

One of the main benefits of implementing Zero Trust architecture is the reduction of the organization's attack surface. Since applications are not directly exposed to the internet and users are only granted application-level access, attackers cannot easily scan or discover internal systems. Even if an account is compromised, the attacker cannot move laterally within the network because access is restricted by strict security policies. This significantly improves the organization's cybersecurity posture and helps protect sensitive business data.

Conclusion

Stage 1 Conclusion

In Stage 1, the project focused on understanding the security challenges associated with traditional VPN architectures and the importance of adopting a modern security model. The study highlighted how legacy VPN systems expose organizations to cyber threats such as unauthorized access, lateral movement, and increased attack surface. By analyzing common web vulnerabilities like SQL Injection, Cross-Site Scripting (XSS), CSRF, and others based on OWASP standards, this stage provided a strong foundation in web application security. The vulnerability assessment of the test environment helped demonstrate how attackers can exploit insecure applications and emphasized the importance of implementing secure coding practices and proper security configurations.

Stage 2 Conclusion

Stage 2 focused on performing vulnerability assessment using the **Nessus** security scanning tool. The scanning process was conducted on the target website **Altoro Mutual Demo Bank** to identify potential security weaknesses. The scan results revealed several informational findings and one low-severity vulnerability related to ICMP timestamp disclosure. This stage demonstrated how automated vulnerability scanners help security professionals detect system weaknesses, analyze network services, and identify configuration issues. The generated reports provided detailed descriptions, severity levels, and remediation recommendations, which are essential for improving system security.

Stage 3 Conclusion

Stage 3 focused on studying the implementation of a **Zero Trust security architecture** using a cloud-based solution such as **Zscaler**. The study highlighted how Zero Trust principles such as identity verification, device posture checking, and least-privilege access can effectively replace traditional VPN architectures. By allowing users to access only specific applications instead of the entire network, Zero Trust significantly reduces the attack surface and prevents lateral movement within enterprise environments. The analysis of different use-case scenarios demonstrated how secure remote access can be achieved while maintaining strong security controls. Overall, this stage emphasized the importance of modern cloud-based security solutions in protecting enterprise networks.

Future Scope

Stage 1 Future Scope

In the future, the project can be expanded by performing deeper penetration testing using advanced tools and techniques. Additional vulnerability categories from the OWASP Top 10 can be explored to identify complex security issues in modern web applications. The project can also include automated vulnerability detection systems and secure coding practices to prevent vulnerabilities during the development phase. Integrating security testing into the software development lifecycle (SDLC) will further improve application security.

Stage 2 Future Scope

Future work can include performing more advanced vulnerability scanning using multiple security tools such as **OpenVAS**, **Burp Suite**, and **Nikto**. Continuous vulnerability monitoring and automated patch management can also be implemented to strengthen system security. In addition, integrating

vulnerability scanning with Security Information and Event Management (SIEM) systems will allow organizations to detect and respond to threats more effectively.

Stage 3 Future Scope

Future improvements can involve implementing a full Zero Trust architecture in real enterprise environments. The project can also explore advanced security technologies such as micro-segmentation, behavioral analytics, and artificial intelligence-based threat detection. Integration with identity management systems and cloud security platforms can further enhance security. Additionally, implementing **Zero Trust Network Access (ZTNA)** solutions in large-scale organizations will help provide secure access to cloud applications and enterprise resources

Topics Explored

- Zero Trust Security Architecture
- Limitations of Traditional VPN Systems
- Web Application Vulnerabilities (OWASP Top 15)
- Vulnerability Assessment and Risk Analysis
- Network Security and Access Control
- Secure Remote Access Technologies
- Cloud-based Security Solutions
- Application-level Access Control and Micro-Segmentation

Tools Explored

- **Nessus** – Vulnerability scanning and security assessment
- **Kali Linux** – Penetration testing environment
- **Burp Suite** – Web application security testing
- **OWASP ZAP** – Automated web vulnerability scanner
- **Zscaler Platform – Zero Trust secure access implementation